

Informe de Incidente según ISO 27001

Vulnerabilidad de Inyección SQL en DVWA

1. Introducción

Este informe documenta la identificación de una vulnerabilidad de inyección SQL en la aplicación DVWA, instalada en una máquina virtual Debian con fines educativos y en un entorno controlado.

2. Descripción del incidente

Durante la prueba en el módulo SQL Injection, se detectó que el campo User ID permite ingresar consultas manipuladas. Esto permitió alterar la consulta SQL original y obtener varios registros de usuarios desde la base de datos.

3. Método utilizado

Se ingresó el siguiente payload en el campo User ID:

```
1' OR '1'='1
```

Esta condición siempre resulta verdadera, por lo que la aplicación devolvió múltiples usuarios en lugar de uno solo.

4. Evidencia

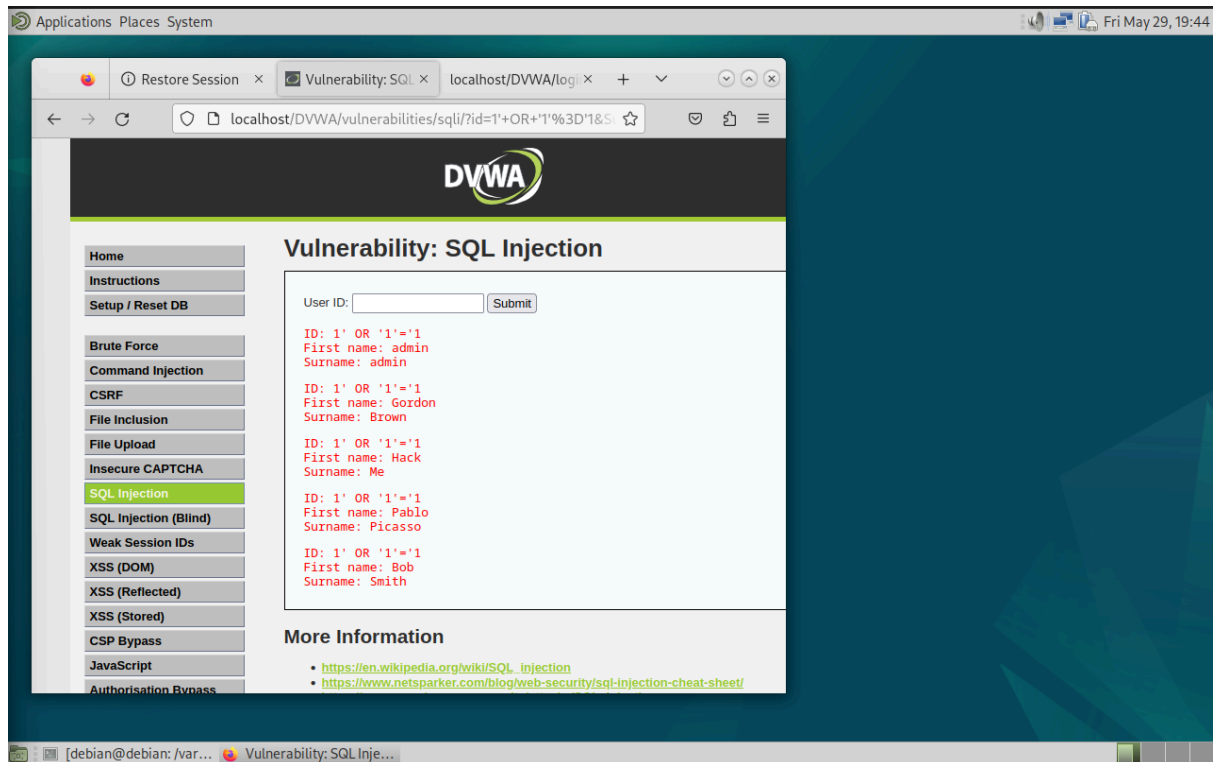


Imagen: Resultado de la explotación de SQL Injection en DVWA.

5. Impacto

En un sistema real, esta vulnerabilidad podría permitir el acceso no autorizado a información sensible, exposición de usuarios, modificación de datos o compromiso de la base de datos. Afecta principalmente la confidencialidad y la integridad de la información.

6. Recomendaciones

Se recomienda implementar consultas preparadas, validar correctamente las entradas del usuario, aplicar el principio de mínimo privilegio en la base de datos y realizar pruebas de seguridad periódicas para detectar vulnerabilidades.

7. Conclusión

La prueba confirmó que DVWA es vulnerable a inyección SQL en el módulo evaluado. El ejercicio demuestra la importancia de aplicar buenas prácticas de desarrollo seguro para proteger las aplicaciones web y sus bases de datos.